Consultoría para la Gobernanza y Gestión de un Security Operations Center (SOC) en la empresa Sentinel Cybersec

Ricardo Artavia Solano, Bryan Moya Marenco, Sebastián González Rojas, Yirlania Córdoba, Fabian Rivera, Herberth Masís Canales

Escuela de Ingeniería en Sistemas, Universidad Fidélitas
San José, Costa Rica

rartavia50691@ufide.ac.cr
bmoya50254@ufide.ac.cr
ycordoba90109@ufide.ac.cr
sgonzalez70322@ufide.ac.cr
hmasis20093@ufide.ac.cr
frivera50479@ufide.ac.cr

Abstract*— This project presents the design of a governance and internal management model for the Security Operations Center (SOC) of Sentinel Cybersec, a company focused on cybersecurity services. The study addresses the need to organize decision-making processes, define roles and responsibilities, and improve the overall management of information security within the organization. The proposal is based on internationally recognized frameworks such as COBIT 2019, ISO/IEC 27001:2022 and ISO/IEC 27035, which provide guidelines for governance, risk management and incident handling. Through a structured analysis of the current situation of the SOC, key gaps were identified in terms of organization, process definition, and alignment with business objectives. As a result, a governance and management model is proposed, including policies, organizational structure, process definition and strategic initiatives aimed at strengthening the operation of the SOC. The project does not include the technical implementation of tools but focuses on establishing a solid foundation for improving efficiency, decision-making and security management. This work contributes to enhancing the operational performance of the SOC and supports the alignment between cybersecurity practices and business objectives, promoting a more structured and effective approach to information security management.

I. INTRODUCCIÓN

Hoy casi todo depende de sistemas, redes y datos. Por esta razón, la seguridad de la información dejó de ser únicamente un tema técnico y pasó a convertirse en un aspecto crítico para la operación y continuidad de las organizaciones [4]. Cuando ocurre un incidente de seguridad, el impacto suele ser inmediato y puede reflejarse en servicios interrumpidos, información comprometida y decisiones urgentes que afectan directamente al negocio [7].

En este contexto, el Security Operations Center (SOC) cumple un rol clave, ya que es el área encargada del monitoreo de eventos de seguridad y del apoyo en la respuesta ante incidentes [1]. Sin embargo, en muchas organizaciones el SOC opera con un enfoque muy técnico y reactivo, lo que provoca desorden en la toma de decisiones, dificultades para el escalamiento de incidentes y poca claridad sobre el valor que realmente aporta al negocio [2]. Esta situación hace evidente la necesidad de establecer un marco de gobernanza y gestión que permita ordenar su funcionamiento, alineado con marcos internacionales como COBIT 2019, ISO/IEC 27001 e ISO/IEC 27035 [6], [4], [5].

Por ello, este trabajo plantea una consultoría enfocada en la gobernanza y gestión del SOC de Sentinel Cybersec, iniciando por la definición de los objetivos del proyecto, su justificación, los beneficios esperados y los criterios de éxito. El propósito es brindar a la empresa una base clara y estructurada para mejorar la gestión de la seguridad de la información, sin incluir dentro del alcance la implementación técnica de herramientas o soluciones.

II. OBJETIVOS

A. Objetivo general

Definir una consultoría orientada a la gobernanza y gestión del Security Operations Center (SOC) para la empresa Sentinel Cybersec, con el fin de ordenar la toma de decisiones y la gestión de la seguridad de la información de acuerdo con los objetivos del negocio, alineada con los marcos de referencia COBIT 2019 e ISO/IEC 27001:2022. [6], [4].

B. Objetivos específicos

- Establecer lineamientos que permitan integrar el SOC dentro de la estructura del área de tecnologías de información, definiendo de manera clara los roles y responsabilidades asociados a la seguridad de la información, con referencia a los objetivos de gestión APO01 y APO07 de COBIT 2019 [6]. Identificar los aspectos clave que debe considerar la gobernanza del SOC para mejorar la organización del monitoreo de seguridad y la gestión de incidentes, tomando como base los dominios EDM y APO de COBIT 2019 y los controles de ISO/IEC 27001:2022 [6], [4], sin abordar la implementación técnica de soluciones.
- Diagnosticar la situación actual del SOC de Sentinel Cybersec, evaluando sus procesos, estructura organizacional y nivel de madurez, considerando los principios de COBIT 2019 y los requisitos del estándar ISO/IEC 27001:2022 [6], [4].
- Elaborar una propuesta de gobernanza de TI que incluya políticas, estructura organizacional, procesos en formato SIPOC y una cartera de proyectos estratégicos, alineada con los marcos COBIT 2019 e ISO/IEC 27001:2022 [6], [4].
- Definir los beneficios que puede obtener Sentinel Cybersec al contar con una consultoría enfocada en la gobernanza y gestión del SOC, considerando la generación de valor, optimización de recursos y mejora de la rendición de cuentas [6].

III. MARCO TEÓRICO REFERENTE A GOBERNANZA Y GESTIÓN DE TICS

La seguridad de la información se ha convertido en un elemento esencial dentro de las organizaciones, especialmente en aquellas que brindan servicios de ciberseguridad. Estas empresas dependen directamente de la protección de los activos digitales, por lo que cualquier vulnerabilidad puede comprometer la confianza de los clientes y la continuidad del negocio [4].

De acuerdo con la norma ISO/IEC 27001, la seguridad de la información debe gestionarse mediante un enfoque sistemático basado en la identificación de riesgos, la implementación de controles y la mejora continua de los procesos [4]. Este enfoque permite garantizar la confidencialidad, integridad y disponibilidad de la información, aspectos fundamentales en cualquier organización.

En el caso de Sentinel Cybersec, la gestión de la seguridad no puede limitarse únicamente a herramientas tecnológicas, sino que debe estar respaldada por una adecuada gestión interna que permita controlar y supervisar los procesos de seguridad.

A. *Seguridad de la información y operación de un SOC*

La seguridad de la información constituye uno de los pilares fundamentales en las organizaciones actuales, especialmente en aquellas que brindan servicios de ciberseguridad. Su objetivo principal es proteger los activos de información frente a amenazas internas y externas, garantizando la confidencialidad, integridad y disponibilidad de los datos [4]. Estos principios son esenciales en entornos donde la información representa un recurso crítico para la operación del negocio.

La norma ISO/IEC 27001 establece un enfoque sistemático para la gestión de la seguridad mediante la implementación de un Sistema de Gestión de Seguridad de la Información (SGSI), el cual se basa en la identificación de riesgos, la aplicación de controles técnicos y administrativos, y la mejora continua de los procesos [4]. Este estándar permite a las organizaciones estructurar sus prácticas de seguridad y alinearlas con objetivos estratégicos corporativos. Dentro de este contexto, el Security Operations Center (SOC) se posiciona como el componente operativo encargado de ejecutar las actividades de seguridad a diario. Su función principal es monitorear de forma continua los eventos generados en la infraestructura tecnológica, identificar posibles amenazas y coordinar la respuesta ante incidentes [1]. Para ello, el SOC utiliza herramientas como sistemas SIEM (Security Information and Event Management), IDS/IPS y plataformas de análisis de eventos, que permiten correlacionar información y detectar comportamientos anómalos.

Además, el SOC opera generalmente bajo un esquema de niveles (Nivel 1, Nivel 2 y Nivel 3), donde cada uno cumple funciones específicas relacionadas con el monitoreo inicial, el análisis profundo y la respuesta avanzada ante incidentes. Esta estructura permite una gestión más organizada de los eventos de seguridad y una distribución eficiente de la carga analítica. Sin embargo, tal como lo señala ENISA, muchos SOC enfrentan limitaciones debido a la falta de procesos definidos y una estructura organizativa adecuada, lo que genera dificultades en la priorización de incidentes y en la coordinación de las respuestas [2]. Esto demuestra que la efectividad de un SOC no depende únicamente de la tecnología, sino también de la forma en que se gestionan y supervisan sus operaciones de manera integral. En el caso de Sentinel Cybersec, el SOC representa el núcleo del servicio

ofrecido, por lo que su correcta operación es clave para garantizar la calidad del servicio y la protección de los activos de sus clientes.

B. *Gobernanza de TI aplicada a la ciberseguridad*

La gobernanza de Tecnologías de Información (TI) se refiere al conjunto de prácticas que permiten dirigir, evaluar y supervisar el uso de la tecnología dentro de una organización. Su propósito es asegurar que las TI generen valor, optimicen los recursos y se alineen con los objetivos estratégicos del negocio [6]. De acuerdo con el marco de referencia COBIT 2019, la gobernanza implica la evaluación de las necesidades de las partes interesadas, la definición de una dirección estratégica clara y el monitoreo del desempeño de los procesos institucionales [6]. Este marco proporciona una estructura que permite establecer responsabilidades claras en la alta dirección, definir políticas de cumplimiento y mejorar la toma de decisiones dentro de la organización.

En el ámbito de la ciberseguridad, la gobernanza adquiere una importancia aún mayor, ya que las decisiones relacionadas con la protección de datos deben considerar tanto los riesgos tecnológicos como los impactos financieros y reputacionales en el negocio. Esto implica que la seguridad no debe gestionarse únicamente desde un enfoque técnico aislado, sino como parte fundamental de la estrategia organizacional corporativa. Aplicado a un SOC, la gobernanza permite definir con autoridad quién toma decisiones críticas, cómo se priorizan los incidentes según el impacto al negocio, qué procesos estandarizados deben seguirse y cómo se supervisa el cumplimiento de los objetivos de seguridad. Además, facilita la integración de marcos de referencia internacionales como ISO/IEC 27001 y NIST, lo que contribuye a fortalecer la gestión de la seguridad de la información [4], [7].

Otro aspecto relevante es la definición de roles y responsabilidades, comúnmente representados mediante herramientas como la matriz RACI (Responsible, Accountable, Consulted, Informed), la cual permite identificar quién es responsable de la ejecución, quién aprueba el resultado, quién debe ser consultado por su conocimiento experto y quién debe ser informado del progreso en cada proceso operativo. Esto reduce la ambigüedad y mejora sustancialmente la coordinación dentro de los distintos niveles del SOC [6]. En el caso de Sentinel Cybersec, la implementación de un modelo de gobernanza robusto permitirá organizar el funcionamiento del centro de operaciones, mejorar la toma de decisiones gerenciales y asegurar que las actividades de seguridad están plenamente alineadas con los objetivos de crecimiento del negocio.

C. *Gestión de incidentes y mejora continua*

La gestión de incidentes de seguridad es un proceso fundamental dentro de un SOC, ya que permite responder de manera estructurada ante eventos que pueden comprometer la seguridad de la información. Este proceso no solo busca contener los incidentes de forma reactiva, sino también aprender de ellos para mejorar continuamente la postura defensiva. El National Institute of Standards and Technology (NIST) define un ciclo de vida para la gestión de incidentes que incluye las fases de preparación, detección y análisis, contención, erradicación y recuperación [7]. Este enfoque metodológico permite a las organizaciones actuar de forma organizada durante una crisis, reducir el impacto de los incidentes y restablecer la operación normal de los servicios en el menor tiempo posible.

Por su parte, la norma ISO/IEC 27035 complementa este modelo al establecer lineamientos detallados para la gestión de incidentes, destacando la importancia crítica de la documentación rigurosa, la comunicación efectiva entre áreas y el análisis posterior de los eventos (post-incident activity) [5]. Este análisis permite identificar con precisión las causas raíz de los incidentes y aplicar medidas correctivas que eviten su repetición futura. En un SOC, la gestión de incidentes se encuentra directamente relacionada con la capacidad de respuesta y eficiencia del equipo de seguridad. Una gestión adecuada permite reducir métricas clave de desempeño como los tiempos medios de detección (MTTD) y respuesta (MTTR), mejorando la eficiencia operativa y fortaleciendo la postura de seguridad global de la organización.

Asimismo, la mejora continua es un elemento clave y obligatorio dentro de este proceso. Cada incidente atendido representa una oportunidad estratégica para fortalecer los controles técnicos, optimizar los procesos operativos y mejorar la coordinación entre los diferentes niveles del SOC. Este enfoque permite que la organización evolucione y se adapte proactivamente frente a nuevas tácticas de ataque y amenazas emergentes. En Sentinel Cybersec, la implementación de procesos estructurados de gestión de incidentes permitirá no solo mejorar la respuesta ante ataques, sino también generar conocimiento institucionalizado que contribuya a fortalecer la seguridad de los sistemas de sus clientes de manera sostenible.

IV. DIAGNÓSTICO DE LA SITUACIÓN ACTUAL DEL ÁREA DE TECNOLOGÍAS DE LA INFORMACIÓN

A. Procesos del área de TI

Los procesos actuales se encuentran orientados principalmente a la operación técnica, con un enfoque reactivo frente a los incidentes de seguridad. Si bien el SOC cumple funciones esenciales dentro de la organización, se evidencian debilidades en la formalización, estandarización y documentación de sus procesos.

Uno de los procesos principales es el monitoreo de eventos de seguridad, el cual se realiza de manera continua mediante herramientas tecnológicas que permiten detectar actividades sospechosas dentro de la infraestructura. No obstante, este

proceso carece de criterios estandarizados para la clasificación y priorización de alertas, lo que puede afectar la eficiencia en la atención de incidentes.

En cuanto a la gestión de incidentes, se observa que las acciones se ejecutan conforme los eventos son detectados, sin seguir un procedimiento formalmente definido. No se identifican fases estructuradas como preparación, detección, análisis, contención, erradicación y recuperación, lo que limita la capacidad de respuesta organizada ante amenazas [7].

El proceso de escalamiento de incidentes también presenta debilidades, ya que se realiza de manera informal entre los diferentes niveles del SOC (Nivel 1, Nivel 2 y Nivel 3), sin lineamientos claros que definan cuándo y cómo debe escalarse un incidente. Esto puede generar retrasos en la toma de decisiones y afectar la gestión oportuna de los eventos críticos.

Asimismo, el análisis de eventos se lleva a cabo desde un enfoque técnico, pero sin el respaldo de metodologías estandarizadas ni criterios de evaluación de riesgos claramente definidos. Esto dificulta la priorización adecuada de los incidentes y la asignación eficiente de recursos.

Por otro lado, el proceso de documentación y reporte de incidentes es limitado, lo que impide generar históricos confiables, lecciones aprendidas y métricas que contribuyan a la mejora continua del SOC [5].

En términos generales, los procesos existentes presentan un bajo nivel de madurez, caracterizado por la falta de estandarización, documentación y alineación con buenas prácticas internacionales como las establecidas por COBIT 2019 e ISO/IEC 27001 [4], [6].

B. Políticas, lineamientos, marco de gobierno de TI

El marco de gobierno de Tecnologías de Información (TI) existente en el SOC de Sentinel Cybersec hace referencia a la forma en que se dirige, controla y supervisa la gestión de la tecnología dentro de la organización. A partir del análisis realizado, se evidencia que dicho marco presenta un nivel bajo de formalización y madurez [3].

En primer lugar, no se identifican políticas formales de seguridad de la información que regulen las actividades del SOC. La ausencia de estas políticas implica que los procesos se ejecutan sin lineamientos claros, lo que puede generar inconsistencias y riesgos en la gestión de la seguridad.

Asimismo, no existen procedimientos documentados que orienten la ejecución de tareas críticas, como la gestión de incidentes, el monitoreo de eventos o la respuesta ante amenazas. Esta falta de lineamientos limita la estandarización de las operaciones y dificulta la replicabilidad de buenas prácticas.

En relación con la estructura organizacional, se observa que los roles y responsabilidades no están claramente definidos. Aunque el SOC opera bajo un esquema por niveles, no se cuenta con una asignación formal de funciones ni con herramientas como matrices RACI que permitan establecer responsabilidades, niveles de autoridad y canales de comunicación [6].

La toma de decisiones dentro del área de TI se caracteriza por ser centralizada y reactiva, sin un proceso estructurado de evaluación, dirección y monitoreo. Esto refleja la ausencia de un enfoque de gobernanza que permita alinear las actividades del SOC con los objetivos estratégicos del negocio [6].

Adicionalmente, se evidencia una falta de alineación con marcos de referencia internacionales como COBIT 2019 e ISO/IEC 27001, los cuales proporcionan lineamientos para establecer una gobernanza efectiva basada en la generación de valor, la gestión de riesgos y la optimización de recursos [4], [6].

Por otra parte, no se utilizan indicadores clave de desempeño (KPIs) y métricas que permitan evaluar la eficiencia del SOC, tales como los tiempos de detección y respuesta ante incidentes. Esto dificulta la medición del desempeño y la implementación de mejoras basadas en datos.

En conjunto, estas condiciones evidencian que el marco de gobierno de TI existente es incipiente, con debilidades en la definición de políticas, la estructuración de procesos, la asignación de responsabilidades y la alineación estratégica.

C. Personal involucrado (organigrama, matriz de roles y responsabilidades actuales del personal TI)

La estructura organizativa busca clarificar los niveles de responsabilidad, autoridad y comunicación dentro del SOC, permitiendo una toma de decisiones más ordenada y alineada con los objetivos estratégicos del negocio. A nivel jerárquico, se establece una relación directa entre la alta dirección y el área de seguridad de la información, asegurando el involucramiento de las partes interesadas clave en la gobernanza de TI.

En este modelo, el Chief Executive Officer (CEO) mantiene la responsabilidad estratégica general, mientras que el Chief Information Security Officer (CISO) asume un rol central en la definición de políticas, gestión de riesgos y supervisión del desempeño del SOC. El SOC Manager continúa siendo responsable de la operación diaria del centro de operaciones, coordinando los distintos niveles de análisis y respuesta a incidentes (Nivel 1, Nivel 2 y Nivel 3).

Esta estructura permite separar claramente las funciones de gobernanza, gestión y operación, tal como lo establece COBIT 2019, facilitando la rendición de cuentas y la evaluación del desempeño de la seguridad de la información.

1) Matriz de Roles y Responsabilidades Actuales:

TABLA 1
Roles y responsabilidades actuales del personal de TI

Rol	Responsabilidad Principal	Enfoque Actual

CEO / CTO	Definición de visión estratégica y adquisición de tecnología.	Estratégico
CISO	Establecimiento de políticas y supervisión de la protección de datos.	Táctico
SOC Manager	Coordinación operativa del equipo y gestión de alertas críticas.	Operativo / Gestión
Analista Nivel 1	Monitoreo 24/7 y detección inicial de eventos de seguridad.	Técnico (Reactivo)
Analista Nivel 2	Análisis profundo de incidentes y validación de impacto.	Técnico (Investigación)
Analista Nivel 3	Respuesta avanzada, mitigación y análisis forense.	Técnico (Respuesta)

D. *Análisis del gobierno de TI de la empresa (Valor Generado)*

El análisis del gobierno de tecnologías de información en Sentinel Cybersec permite identificar que, si bien la organización cuenta con prácticas operativas relacionadas con la seguridad, no dispone de un marco formal de gobernanza de TI que regule la toma de decisiones y la alineación con los objetivos del negocio [6].

Actualmente, el SOC opera bajo un enfoque principalmente técnico y reactivo, centrado en el monitoreo de eventos y la respuesta a incidentes. Existen políticas y procedimientos básicos, como el monitoreo continuo, la gestión de incidentes y el control de accesos; sin embargo, estos no se encuentran integrados dentro de un sistema estructurado de gobernanza.

Desde la perspectiva de COBIT 2019 [6], se identifican debilidades en los dominios de gobierno (EDM) y gestión (APO), especialmente en aspectos como:

- La definición de responsabilidades a nivel estratégico.
- La alineación entre la seguridad de la información y los objetivos del negocio.
- La medición del desempeño del SOC.
- La supervisión y control de las actividades de seguridad.

Asimismo, en relación con el estándar ISO/IEC 27001 [4], se evidencia la ausencia de un Sistema de Gestión de Seguridad de la Información (SGSI) formalmente implementado, lo que limita la estandarización de procesos, la gestión de riesgos y la mejora continua.

Como resultado, la organización enfrenta desafíos como: falta de claridad en la toma de decisiones, procesos poco estructurados, limitada visibilidad para los niveles directivos y uso no optimizado de los recursos tecnológicos y humanos.

En conclusión, aunque Sentinel Cybersec cuenta con una base operativa sólida en su SOC, requiere fortalecer su gobierno de TI mediante la adopción de marcos formales como COBIT 2019 e ISO/IEC 27001, que permitan mejorar la organización, control y alineación estratégica del área de seguridad de la información.

E. *Anàlisis FODA del Àrea de Tecnologìa de Informaciòn*

Fig. 1 Análisis FODA de Sentinel Cybersec.

F. Identificación y evaluación de riesgos del área de TI (sin plan de respuesta)

Como parte del diagnóstico, se identificaron los principales riesgos operativos y de gobernanza que afectan al SOC de Sentinel Cybersec. La evaluación se realizó multiplicando la Probabilidad (escala 1-5) por el Impacto (escala 1-5) para determinar el Nivel de Riesgo inherente, excluyendo los planes de respuesta según el alcance de esta fase. [4].

TABLA 2
Identificación y evaluación de riesgos del SOC

ID	Riesgo	Descripción	Probabilidad
R-01	**Fatiga de alertas (Alert Fatigue).**	El exceso de falsos positivos satura a los analistas, arriesgando la omisión de incidentes críticos reales.	5

R-02	**Incumplimiento de SLAs.**	La falta de procesos estructurados y el escalamiento informal retrasan la contención de amenazas.	4
R-03	**Desalineación de la inversión TI.**	Adquisición de herramientas sin criterios estratégicos, generando gastos sin retorno de valor para el negocio.	4
R-04	**Fuga de talento especializado.**	La naturaleza reactiva del trabajo y la confusión de roles (falta de matriz RACI) aumentan la rotación de personal.	3
R-05	**Incapacidad de mejora continua.**	La ausencia de registros post-incidentes impide aprender de errores pasados y evolucionar frente a nuevas amenazas.	4

V. PROPUESTA DE GOBERNANZA Y GESTIÓN DE TICS

A. Modelo de gobernanza para la toma de decisiones

Para transitar de un enfoque técnico-reactivo a un modelo gestionado, se establece un modelo de gobernanza basado en el dominio EDM (Evaluar, Dirigir y Monitorear) del marco COBIT 2019 [6]. El núcleo de este modelo es la conformación del Comité de Gobernanza de Ciberseguridad (CGC), el cual actúa como el máximo órgano de decisión para el área de TI de Sentinel Cybersec.

Composición: Chief Executive Officer (CEO - Patrocinador), Chief Technology Officer (CTO - Asesor Tecnológico), Chief Information Security Officer (CISO - Director del Comité) y SOC Manager (Voz operativa).

Mecanismo de Toma de Decisiones [6]:

1. Evaluar: Mensualmente, el CISO presenta al Comité el panorama de amenazas, el nivel de riesgo residual del SOC y la evaluación de los recursos actuales.

2. Dirigir: El CEO y el CTO, basándose en la justificación de negocio y el impacto financiero, aprueban los presupuestos, priorizan la cartera de proyectos y ratifican las políticas de seguridad.

3. Monitorear: El Comité revisa las métricas de cumplimiento (KPIs) para asegurar que la gestión del SOC optimice los recursos y genere valor a la organización.

B. Principales procesos a recomendar

Con base en las sanas prácticas de COBIT 2019 [6] e ISO/IEC 27035 [5], se estructuran los procesos críticos para garantizar la trazabilidad entre el gobierno y la gestión. Se definen un proceso estratégico (Gobernanza) y un proceso operativo (Gestión):

TABLA 3
SIPOC: Supervisión y Gobernanza del SOC (Práctica COBIT EDM01 / APO12)

Proveedores (S)	Entradas (I)	Proceso (P)	Salidas (O)	Clientes (C)
CISO, SOC Manager.	Reportes de KPIs, Auditorías de Riesgos.	**1.** Analizar métricas operativas. **2.** Evaluar alineación estratégica. **3.** Aprobar inversiones o cambios. **4.** Emitir directrices gerenciales.	Actas de decisión, Presupuestos aprobados, Políticas firmadas.	Junta Directiva, Operaciones SOC.

TABLA 4
SIPOC: Gestión y Respuesta a Incidentes (Práctica COBIT DSS02)

Proveedores (S)	Entradas (I)	Proceso (P)	Salidas (O)	Clientes (C)
Analistas Nivel 1, Plataforma SIEM	Alerta validada de brecha de seguridad	1. Contención inmediata. 2. Erradicación. 3.Recuperación 4.Post-Mortem	Incidente cerrado, Sistemas restaurados, Lecciones aprendidas.	Clientes afectados, CISO, CGC.

C. Estructura organizativa para dar soporte al proceso con Matriz RACI asociada.

La estructura organizativa propuesta separa explícitamente las responsabilidades de gobernanza de las de gestión [6]. La Alta Dirección (CEO, CTO) y el CISO lideran la capa estratégica y táctica. El SOC Manager asume el control netamente operativo sobre los tres niveles de analistas (Nivel 1: Monitoreo, Nivel 2: Análisis, Nivel 3: Respuesta Avanzada).

Para dar soporte a los procesos y formalizar la asignación de responsabilidades, reduciendo la ambigüedad en la toma de decisiones corporativas [3], se establece la siguiente Matriz RACI:

TABLA 5
Matriz RACI del Security Operations Center

Actividad / Proceso	CEO	CISO	SOC Manager	Analista Nivel 1	Analista Nivel 2 y 3
Aprobación de presupuesto e inversión	A	R	C	I	I
Definición de Políticas de Seguridad	I	R/A	C	I	I
Monitoreo Continuo de Eventos (24/7)	I	I	A	R	C
Contención de Incidentes Críticos	I	C	A	I	R
Comunicación oficial a clientes / entes	A	R	C	I	I

D. Identificación de cartera de proyectos de tecnología de información posibles para la empresa.

Para alcanzar el nivel de madurez propuesto en el modelo de gobernanza, se establecen los siguientes proyectos posibles para la empresa, alineados estratégicamente con los hallazgos del diagnóstico [4], [6]:

1. Constitución e Institucionalización del Comité de Gobernanza: Formalización de estatutos, calendarios corporativos y flujos de aprobación.

2. Desarrollo e Implementación del SGSI: Preparación documental y técnica requerida para perfilar a la empresa hacia una certificación formal en ISO/IEC 27001:2022.[4].

3. Automatización de Respuesta (Playbooks): Implementación de flujos automatizados para la contención de incidentes de baja complejidad, con el fin de liberar carga operativa del personal de Nivel 1.

4. Despliegue de Dashboards Gerenciales: Integración de herramientas de Business Intelligence (BI) para visualizar métricas (MTTR, MTTD) en tiempo real, facilitando el monitoreo por parte de la alta gerencia.

E. Identificación de tendencias para guiar las acciones que orientarán la implementación de tecnologías digitales en la empresa seleccionada.

El modelo de gobernanza adoptado servirá como guía para la evaluación e implementación de las siguientes tendencias del mercado, asegurando que su adopción genere un retorno de valor comprobable [2]:

- Automatización y Orquestación de Seguridad (SOAR): Fundamental para reducir los tiempos de respuesta mediante la ejecución automática de tareas repetitivas de investigación y contención.
- Inteligencia Artificial (IA) y Aprendizaje Automático: Aplicación de IA para el análisis de comportamiento de entidades y usuarios (UEBA), mitigando el riesgo de "fatiga de alertas" al reducir significativamente los falsos positivos.
- Arquitectura Zero Trust (Cero Confianza): Transición hacia un modelo de ciberseguridad que exige validación continua de identidad y postura del dispositivo, eliminando la confianza implícita dentro de la red corporativa.[8].

F. Identificación de alternativas de implementación de su propuesta, la cual incluye tiempos y costos estimados para cada alternativa.

Para facilitar la adopción por parte de Sentinel Cybersec, se plantean tres alternativas de implementación. Los costos son estimaciones referenciales enfocadas en los servicios de consultoría, rediseño de procesos y estructuración del modelo, excluyendo el licenciamiento de software comercial.

TABLA 6
Alternativas de Implementación del Modelo de Gobernanza

Escenario	Alcance Propuesto	Tiempo Estimado	Costo Estimado

1. Gradual (Recomendado)	Formalización del Comité de Gobernanza, adopción de políticas críticas y despliegue de la matriz RACI. Bajo impacto operativo.	6 a 9 meses	₡4.500.000
2. Incremental	Incluye el Escenario 1, sumado a la estandarización total de los procesos SIPOC y programas de capacitación para el SOC.	9 a 12 meses	₡6.800.000
3. Integral (Full)	Adopción total y acelerada. Incluye desarrollo de dashboards automatizados y análisis de brechas pre-auditoría ISO 27001.	12 a 18 meses	₡10.200.000

TABLA 7
COMPARATIVA ANTES Y DESPUÉS DEL SGSI

Área	Antes del SGSI	Después del SGSI
Incidentes	Sin registro formal ni clasificación	Flujos de escalamiento estructurados; alineados a DSS02 (COBIT) e ITIL 4 IM
Riesgo	Evaluación informal; sin SoA documentada	Evaluación ISO 27001 §6.1.2; plan de tratamiento alineado a APO12 (COBIT 2019)
Cumplimiento	Exposición legal ante GDPR y regulaciones locales	Auditorías MEA01/MEA02 operativas; Purview Compliance Manager activo
Gobernanza	TI desalineado de los objetivos del negocio	Alta dirección evalúa el SGSI conforme a cláusula 5.1 ISO 27001 y EDM01/EDM03 de COBIT 2019

VI. CONCLUSIÓN

A lo largo del desarrollo de esta consultoría, ha quedado en plena evidencia que la operatividad y el éxito de un Security Operations Center (SOC) no pueden depender exclusivamente de la adquisición de herramientas tecnológicas avanzadas ni del criterio individual de sus analistas. El diagnóstico inicial de Sentinel Cybersec reveló que operar bajo un enfoque puramente reactivo y aislado genera cuellos de botella operativos, fatiga de alertas y, lo más crítico, una profunda desalineación con la estrategia del negocio. Por lo tanto, la transición hacia un modelo maduro y proactivo requiere obligatoriamente la implementación de un marco de gobernanza sólido y formalizado.

La instauración del Comité de Gobernanza de Ciberseguridad (CGC) actúa como el pilar fundamental de esta transformación estructural. Al adoptar los principios directivos del marco COBIT 2019 [6], específicamente a través del dominio EDM (Evaluar, Dirigir y Monitorear), se garantiza que las decisiones de TI dejen de tomarse en un silo técnico. En su lugar, el comité asegura que cada iniciativa, política o adquisición tecnológica se evalúe en función del valor real que aporta a la organización, optimizando las inversiones y estableciendo un canal claro de rendición de cuentas entre la alta gerencia (CEO, CTO) y las capas operativas (CISO, SOC Manager).

En el plano táctico y operativo, la estructuración de los flujos de trabajo mediante metodologías SIPOC y la estricta delimitación de funciones a través de la matriz RACI dotan al SOC de una claridad procedimental sin precedentes. Al alinear estas prácticas con los controles exigidos por la norma ISO/IEC 27001 [4], la organización no sólo mitiga el riesgo de ambigüedad o parálisis durante incidentes críticos, sino que adquiere la madurez necesaria para gestionar el riesgo de la información de manera documentada y auditable. Además, la adopción de un ciclo de vida formal para la gestión de incidentes transforma las crisis en oportunidades de aprendizaje, asegurando que el análisis post-mortem retroalimenta continuamente el Sistema de Gestión de Seguridad de la Información (SGSI).

Finalmente, la cartera de proyectos de TI y las tendencias tecnológicas propuestas establecen una hoja de ruta vanguardista y escalable. La integración proyectada de arquitecturas Zero Trust [8] y herramientas de orquestación (SOAR) asegura que la empresa se mantenga competitiva frente a un panorama de amenazas en constante evolución. Si Sentinel Cybersec ejecuta los escenarios de implementación recomendados —priorizando un enfoque gradual e incremental—, logrará asimilar estos cambios culturales y de procesos sin interrumpir su operación continua. El resultado definitivo será una organización resiliente, con capacidades de respuesta optimizadas y una estructura que consolida la confianza de sus clientes al garantizar que la ciberseguridad opere como un verdadero motor estratégico del negocio.

VII. REFERENCIAS

[1] Cisco Systems, "What is a Security Operations Center (SOC)?", Cisco, 2022.

[2] ENISA, "Security Operations Centre (SOC) Best Practices", European Union Agency for Cybersecurity, 2021.
[3] ISACA, "COBIT 2019 Framework: Introduction and Methodology", ISACA, Rolling Meadows, IL, 2018.
[4] ISO, "ISO/IEC 27001:2022 Information security, cybersecurity and privacy protection — Information security management systems — Requirements", ISO, Geneva, Switzerland, 2022.
[5] ISO, "ISO/IEC 27035-1:2023 Information technology — Information security incident management", ISO, Geneva, Switzerland, 2023.
[6] ISACA, "COBIT 2019 Framework: Governance and Management Objectives", ISACA, Rolling Meadows, IL, 2018.
[7] National Institute of Standards and Technology (NIST), "Computer Security Incident Handling Guide, SP 800-61 Rev. 2", NIST, 2012.
[8] National Institute of Standards and Technology (NIST), "Zero Trust Architecture, SP 800-207", NIST, 2020.
[9] AXELOS, "ITIL Foundation, ITIL 4 Edition", TSO (The Stationery Office), 2019.